AVÈRO ADVISORS

TEMPLATE 03

START AT ZERO TOOLKIT · TEMPLATE 03

# AI Governance & Readiness Assessment

Score nine dimensions across People, Process and Technology, find your gaps, inventory your use cases and set vendor requirements before you deploy AI.

AI amplifies whatever it touches. Point it at governed, clean data and trained people and it compounds value. Point it at shadow licenses and messy records and it compounds risk. This assessment answers four questions before you buy: How mature is your data governance? Which uses fit your mission and risk tolerance? Can you provide real human oversight? What will you require of vendors?

## Maturity scale

| 1 Ad hoc | 2 Aware | 3 Defined | 4 Managed | 5 Embedded |
|---|---|---|---|---|
| No policy or owner. Individuals experiment on their own. | Risks are discussed. A few rules exist, unevenly applied. | Written policy, named owners, a basic registry. | Policy is enforced, measured and reviewed. Oversight is staffed. | Governance is routine, audited and public. Improvement is continuous. |

## Score nine dimensions

Score honestly with evidence. If you cannot point to a document or a practice, it is not a 3.

| Layer | Dimension and what good looks like (level 4) | Evidence questions | Score 1-5 |
|---|---|---|---|
| People | **1. AI literacy and skills**<br>Staff know what AI can and cannot do, and what data never goes into public tools. Role-based training exists. | ☐ Has every department had practical AI training in the last 12 months?<br>☐ Do staff know your rules on public AI tools and PII?<br>☐ Can supervisors explain where AI is used in their unit? | |
| People | **2. Leadership and sponsorship**<br>A named executive owns AI outcomes. Risk appetite is written down. AI is tied to mission results, not tool counts. | ☐ Is there a named executive owner for AI?<br>☐ Has leadership stated which uses are off limits?<br>☐ Are AI goals expressed as service or cost outcomes? | |
| People | **3. Dedicated team and oversight capacity**<br>Trained reviewers have time to check AI-assisted work. Escalation paths are clear. | ☐ Who reviews AI outputs before they affect a resident or employee?<br>☐ Is that review time budgeted?<br>☐ Is there a path to pause a use that misbehaves? | |
| Process | **4. Governance and policy**<br>A responsible use policy is adopted. New uses go through an approval step. A registry lists every AI use, including individual licenses. | ☐ Is there an adopted AI policy?<br>☐ Do new uses require approval before launch?<br>☐ Do you know every AI tool staff are paying for today? | |
| Process | **5. Transparency and public trust**<br>Residents can see where AI is used. Decisions affecting people can be explained. High-impact uses get community input. | ☐ Is there a public list of AI uses?<br>☐ Can you explain an AI-assisted decision to a council member?<br>☐ Were affected communities consulted on high-impact uses? | |

| Layer | Dimension and what good looks like (level 4) | Evidence questions | Score 1-5 |
|---|---|---|---|
| Process | **6. Compliance and legal**<br>Privacy, public records, retention and civil rights are reviewed for each use. Procurement clauses exist. Practice aligns with the NIST AI RMF. | ☐ Are AI prompts and outputs covered by retention rules?<br>☐ Has counsel reviewed civil rights exposure?<br>☐ Do contracts include AI-specific clauses? | |
| Technology | **7. Security and privacy**<br>Data is classified. Public model use is controlled. Vendors are barred from training on your non-public data. | ☐ Is sensitive data (PII, CJIS, HIPAA) classified and tagged?<br>☐ Are public AI tools blocked or governed on agency devices?<br>☐ Do vendor terms prohibit training on your data? | |
| Technology | **8. Infrastructure and integration**<br>Identity, APIs, logging and monitoring support AI safely. There is a sandbox for pilots. | ☐ Can you log and audit what an AI feature did?<br>☐ Is there a safe environment for pilots?<br>☐ Do core systems expose usable APIs? | |
| Technology | **9. Data quality and ownership**<br>Every key dataset has an owner and quality standards. Lineage is known. | ☐ Does each key dataset have a named owner?<br>☐ Would you trust this data to drive an automated flag?<br>☐ Is master data clean enough to convert? | |

## Read your score

| Average | Readiness | What to do next |
|---|---|---|
| Below 2.0 | **Foundation first** | No production AI. Adopt a policy, name owners, build a registry, start data cleanup. |
| 2.0 to 2.9 | **Low-risk pilots** | Internal productivity uses only, with human review and no PII in public models. |
| 3.0 to 3.9 | **Scale with oversight** | Expand internal use. Add decision support where a person makes the final call. |
| 4.0 and up | **Ready for higher impact** | Consider resident-facing uses with impact assessments, public registry and audit. |

**Override rule.** A score of 1 on Governance and policy, Security and privacy, or Data quality caps your readiness at Foundation first, whatever the average says.

## Gap plan

| Dimension | Now | Target (12 mo) | Actions to close the gap | Owner | Due |
|---|---|---|---|---|---|
| | | | | | |
| | | | | | |
| | | | | | |
| | | | | | |
| | | | | | |

## AI use case inventory

**Tier 1, Productivity.** Drafting, summarizing, search. Internal only, no PII in public models.

**Tier 2, Decision support.** Flags anomalies or prioritizes work. A person decides.

**Tier 3, Consequential.** Touches eligibility, benefits, enforcement or employment. Needs approval, impact assessment and public disclosure.

| Use case | Department | Data used / PII? | Tier | Human review point | Status |
|---|---|---|---|---|---|
| | | | | | |
| | | | | | |
| | | | | | |
| | | | | | |
| | | | | | |
| | | | | | |

## Human oversight protocol

- ☐ Each Tier 2 and Tier 3 use has a named reviewer and a backup.
- ☐ Reviewers are trained on the specific tool and its known failure modes.
- ☐ Reviewers can override, and overrides are logged.
- ☐ There is a documented way to pause or switch off the feature.
- ☐ Outcomes are sampled for errors and bias on a set schedule.
- ☐ Decision lineage is kept for audits and council questions.

## Require of every vendor

- ☐ No training on your non-public data without written consent.
- ☐ Disclosure of every embedded AI feature and the model provider behind it.
- ☐ The ability to disable AI features without losing core function.
- ☐ Explainability for outputs that affect residents or employees.
- ☐ Bias and accuracy testing results, and your right to audit.
- ☐ Data residency, deletion on exit and portability.
- ☐ Incident notification within a defined window.
- ☐ Price protection on AI add-ons that appear after signing.

Governance before AI. Inventory before action. The agencies that move fastest later are the ones that did this page first.

From *Start at Zero: Leading High-Stakes Modernization in the Age of AI* by Abhijit Verekar. Free to use and adapt inside your agency. © 2026 Avero Advisors. More at startatzero.averoadvisors.com and avavero.substack.com.